

3

BIT703 Web technologies

Assessment 3

Weighting

40%

Learning outcomes

- 3 Develop a web application demonstrating best practice and using current standards in client-side and server-side scripting and web interface design.
- 4 Select the foremost technologies for application development using current scripting, database and information security standards.
- 6 Analyse web application performance on a variety of platforms to test the behaviour of scripts and resolve any functional issues.

Instructions

Complete and submit your assessment according to the Open Polytechnic's [Assessments webpage](#). This includes information on academic integrity, formatting, word limits and referencing.

- Include your name, your student number and the assessment number.
- Number your pages.

Submission

- Submit your assessment in one zipped folder.
- Submit your work through your iQualify course.
- Emailed assessments will not be accepted.
- You will receive an automated notice advising you of your successful submission.

By submitting your assessment, you confirm that it is your own original work.

Assessment information

What you will need to complete this assessment:

- Relevant technologies and software installed.

Submission instructions

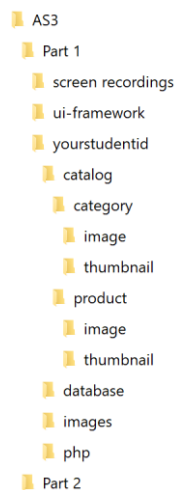
Before you begin, read the marking schedule found at the end of the task. This will give you a clear understanding of how your work will be marked.

You must submit a zipped folder containing all the necessary assessment documentation. Name your zipped folder 'BIT703_A3_YourStudentNumber.zip'.

Your zipped folder must include:

- a folder containing:
 - UI frameworks files (HTML, CSS, JS and images)
 - Catalog and product images and thumbnails
 - database script
 - PHP files
 - SQL files
- a PowerPoint presentation containing a screen recording and/or annotated screenshots named 'YourStudentNumber_A3.pptx' (all three tasks of Part 1 can be recorded in the same PowerPoint file)
- a word-processed document containing your answers to Task 3 named 'YourName_YourStudentNumber_A3.docx'.

Make sure the folder structure follows the hierarchy shown in the image:



Task 1 Create a multi-user authentication interface using frontend and backend technologies

Scenario

In Assessment 1, you were tasked with creating the frontend pages for an e-commerce web application. The next task is to begin writing the backend admin panel of an e-commerce web application, with emphasis in this task on user management.

To complete this task, you will need the PHP and MySQL technology stack you used in the first assessment. You will create a database user for the database, followed by a table schema that contains the user accounts for the web application.

Requirements for Task 1

- a. Create a database called 'BIT703'
 - Create an initial MySQL database user named 'dbadmin' with the password 'letSadmin'. Ensure the database user has the following privileges for the 'BIT703' database:
 - Add records
 - Edit records
 - Remove records.
 - Create a table schema, 'users', that can accommodate the user accounts for the web application:
 - Consider elements such as:
 - Userid
 - User full name
 - Email address
 - Hashed password
 - Access level (Admin, Manager, Salesperson, Customer)
 - Account active yes/no
 - Include at least one record for each access level
 - Use the table schema to create database objects and sample data
 - Verify that the database schema, database objects and sample data have been correctly created.

(10 marks)

- b. Create a configuration file in PHP to store the database credentials and constant values needed for this web application.
 - Create a database connection file in PHP to connect the backend side to the database
 - This database connection must be used for all database operations performed by PHP.

(10 marks)

- c. Develop the admin interface, which includes a login page and a page to list and manage users for the e-commerce web application.
- You must write PHP code to enable the web application to perform CRUD operations.
 - Below is a list of requirements for the admin interface. An administrator should be able to:
 - log in to the admin interface using the admin user account
 - add a user account
 - edit a user account
 - delete a user account.

(30 marks)

- d. To demonstrate that the web application meets the requirements above, perform the above CRUD operations using the admin dashboard with the following:
- Add user: [Job bloggs, jbloggs@mail.com, 'password', Customer, Yes]
 - Edit user: change name to 'Joe Bloggs'
 - Delete user: Joe Bloggs

(10 marks)

Submission

Submit a screen recording and/or annotated screenshots of the database tables and the configuration files. You should use the [screen recorder in PowerPoint to record your video](#). You may include written explanations that support your work.

(Total for Task 1: 60 marks)

Task 2 Implement CSRF/XSS protections and follow OWASP best practices

Scenario

In the previous task, you created the user account management for a web application. In this task, you are expected to 'harden' the security of these pages to prevent unauthorised access to the user accounts.

Requirements for Task 2

- a. Integrate the necessary CSRF protections into all pages of the logon system. Use the following as a guide: <https://alessiopuppialchemy.com/2024/11/07/protecting-web-apps-a-complete-guide-to-csrf-tokens-in-php/>

(10 marks)

- b. Comment on any XSS vulnerabilities that may exist in the authentication pages of the web application.

(Word count guideline: 100 words)

(5 marks)

- c. Demonstrate that the authentication pages of the web application are not subject to SQL injection attacks by attempting at least three different SQL injection methods/attacks (for example, '1 OR 1=1') and recording the outcome.

(10 marks)

Submission

Submit a screen recording and/or annotated screenshots of the database tables and the configuration files. You should use the [screen recorder in PowerPoint to record your video](#). You may include written explanations that support your work. Your video should not be longer than 5 minutes.

(Total for Task 2: 25 marks)

Task 3 Evaluate a given website/web application against a range of measurable metrics

Scenario:

Write a report to analyse the performance of the following website:

- <https://www.thewarehouse.co.nz/>

Requirements for Task 3

The performance should be tested on at least **two** devices (for example, tablet and mobile device). Your report should consider at least **three** of the following criteria:

- Usability (user interactions, accessibility features, alternate captions, etc.)
- Functionality (tested as an application, impact of JavaScript to increase performance, for example, lazy loading, performance budgets)
- Page and asset load times
- Responsiveness.

Your report must include:

- a comparison of performance
- potential issues that testing has identified, with explanations as to how you would resolve them
- a summary of your findings, including annotated screenshots and detailed descriptions to support your findings.

(Word count guideline / Word limit: 1000 words)

(15 marks)

(Total for Task 3: 15 marks)

(Total for Assessment 3: 100 marks)

Marking schedule

Task 1: Create a multi-user authentication interface using frontend and backend technologies					
a. Create a database and table schema	8–10 marks	6.5–7.5 marks	5–6 marks	4–4.5 marks	1–3.5 marks
	The database is meticulously created, and the 'dbadmin' user is configured with all specified privileges, ensuring secure and efficient management of records. The 'users' table schema is expertly designed, accommodating all necessary elements, including user ID, full name, email, hashed password, access level and account status. The schema includes comprehensive records for each access level, demonstrating a robust understanding of user management. The database script is executed flawlessly, creating all objects and sample data with precision. Verification shows impeccable accuracy.	The database is well-established, with the 'dbadmin' user granted the necessary privileges to manage records effectively. The 'users' table schema is well-constructed, covering all essential elements, and includes records for each access level. The database script runs smoothly, creating the required objects and sample data, with minor areas for improvement in execution. Verification confirms the correct creation of schema and data.	The database is adequately created, with the 'dbadmin' user set up to add, edit and remove records. The 'users' table schema is implemented across all relevant elements, allowing for basic user account management. Records exist for each access level, meeting minimum requirements. The database script is executed to create necessary objects and sample data, ensuring functionality. Verification demonstrates that the schema and data have been correctly established.	The database creation shows poor execution, with the 'dbadmin' user having incomplete or incorrect privileges. The 'users' table schema is inadequately designed, is missing some key elements, and the records for access levels are incomplete. The database script is executed with errors, resulting in incomplete or incorrect database objects and sample data. Verification reveals several issues.	The database setup is weak, with significant errors in creating the database and configuring user privileges. The 'users' table schema is poorly constructed, lacking critical elements and records for access levels. The database script fails to execute properly, leading to missing or incorrect database objects and data. Verification shows major discrepancies.
b. Create a configuration file	8–10 marks	6.5–7.5 marks	5–6 marks	4–4.5 marks	1–3.5 marks
	The PHP configuration file is expertly crafted, securely storing all database credentials and constant values necessary for the web application.	The PHP configuration file is well-organised, effectively storing database credentials and constant values.	The PHP configuration file is adequately created, storing all necessary database credentials and constant values to ensure a pass.	The PHP configuration file is poorly organised, with potential security risks in storing database credentials and constants.	The PHP configuration file is weak, with significant errors in storing credentials and constants, posing serious security risks.

	It follows best practices for security and organisation. The database connection file is meticulously developed, ensuring robust and efficient connection to the database for all PHP operations. The connection is optimised for performance and security, with comprehensive error handling.	It adheres to good security practices, though there may be minor areas for improvement. The database connection file is well-constructed, reliably connecting the backend to the database for all operations. It includes error handling, but it may not be fully optimised.	The database connection file is implemented across all relevant operations, providing a functional connection to the database. While the connection may not be fully optimised, it meets essential requirements for functionality.	The database connection file shows inadequate development, leading to unreliable connections and potential errors in database operations. Error handling is minimal, and the files may not meet standard practices.	The database connection file is either missing or improperly constructed, failing to establish a reliable connection for PHP operations. There is little to no error handling, resulting in frequent operational issues.
c. Develop the admin interface	24–30 marks	19.5–23.5 marks	15–19 marks	12–14.5 marks	1–11.5 marks
	The admin interface is expertly developed, providing a seamless login experience and a comprehensive user management system. The PHP code for CRUD operations is meticulously written, ensuring high efficiency and security. Administrators can easily log in, and the interface allows for intuitive addition, editing and deletion of user accounts.	The admin interface is well-developed, offering a reliable login system and functional user management capabilities. The PHP code for CRUD operations is well-constructed, with minor areas for optimisation. Administrators can log in and manage user accounts effectively, though the interface may lack some advanced features.	The admin interface is adequately implemented. It provides basic login functionality and user management through PHP-coded CRUD operations. Administrators can perform essential tasks such as logging in and managing user accounts, with the interface meeting minimum requirements for functionality and usability.	The admin interface shows poor development, with a basic and potentially unreliable login system. The PHP code for CRUD operations is inadequately written, leading to limited functionality in user management. Administrators may encounter difficulties in logging in or managing user accounts due to insufficient features or errors.	The admin interface is underdeveloped, with significant issues in login functionality and user management capabilities. The PHP code for CRUD operations is either missing or improperly constructed, resulting in frequent issues and a lack of essential features for administrators.
d. Demonstration of CRUD operations	8–10 marks	6.5–7.5 marks	5–6 marks	4–4.5 marks	1–3.5 marks
	The demonstration of CRUD operations through the admin dashboard is executed flawlessly. Adding the user [Job bloggs, jbloggs@mail.com, 'password', Customer, Yes] is seamless, with all fields correctly	The demonstration of CRUD operations is conducted effectively through the admin dashboard. The user [Job bloggs, jbloggs@mail.com, 'password', Customer, Yes] is added with minor issues in field validation or confirmation.	The demonstration of CRUD operations meets essential requirements. The user [Job bloggs, jbloggs@mail.com, 'password', Customer, Yes] is added, with all relevant details entered adequately.	The demonstration of CRUD operations is poorly executed, with issues adding the user [Job bloggs, jbloggs@mail.com, 'password', Customer, Yes], such as incorrect data entry or missing fields.	The demonstration of CRUD operations is inadequate, with significant challenges in adding the user [Job bloggs, jbloggs@mail.com, 'password', Customer, Yes], leading to incomplete or incorrect records.

	populated and reflected in the user list. Editing the user to change the name to 'Joe Bloggs' is handled with precision, updating all necessary records. Deleting the user 'Joe Bloggs' is performed efficiently, with appropriate confirmation prompts and audit logging.	Editing the user's name to 'Joe Bloggs' is completed successfully, though with slight room for improvement in user feedback. Deleting the user is handled correctly, with necessary confirmations in place.	Editing to change the name to 'Joe Bloggs' is completed, ensuring the change is reflected. Deleting the user is performed satisfactorily, with basic confirmation. While the process may not be highly polished, it is functional and demonstrates the necessary capabilities.	Editing the name to 'Joe Bloggs' may encounter errors or incomplete updates. Deleting the user is possible but lacks proper confirmation or error handling.	Editing the name to 'Joe Bloggs' fails or is executed improperly. Deleting the user lacks essential functionality, resulting in errors or unresolved actions.
Task 2: Implement CSRF/XSS protections and follow OWASP best practices					
a. CSRF protections	8–10 marks	6.5–7.5 marks	5–6 marks	4–4.5 marks	1–3.5 marks
	The integration of CSRF protections across the login system is executed with exceptional precision. Following the guidance from the specified resource, CSRF tokens are implemented seamlessly on all relevant pages, ensuring robust protection against attacks. The tokens are securely generated, stored and validated, with advanced error handling and user feedback mechanisms.	The CSRF protections are well-integrated into the login system, effectively using the guidance from the resource. Tokens are correctly generated and validated on most pages, with minor areas for improvement in token management or user feedback. The implementation aligns with standard security practices, providing a reliable defence against CSRF attacks.	The integration of CSRF protections meets essential requirements. CSRF tokens are implemented on the necessary pages of the login system, following the guide's basic instructions. While the implementation may not include advanced features or optimisations, it provides functional protection against CSRF attacks.	The integration of CSRF protections is poorly executed, with inconsistent or incomplete implementation across the login system. Tokens may be generated or validated incorrectly, leading to potential vulnerabilities. The approach lacks alignment with recommended practices, resulting in minimal protection against CSRF attacks.	The integration of CSRF protections is inadequate, with significant errors or omissions in implementing tokens across the login system. The process fails to follow the guidance effectively, resulting in little to no defence against CSRF attacks. Essential steps such as token validation or secure storage are missing, compromising the system's security.
b. XSS vulnerabilities	4–5 marks	3.5 marks	2.5–3 marks	2 marks	1–1.5 marks
	The analysis of XSS vulnerabilities in the authentication pages is thorough and insightful. Every potential vulnerability is identified with precision, and	The examination of XSS vulnerabilities is well-executed, identifying most potential issues within the authentication pages. The commentary includes a solid explanation of	The commentary on XSS vulnerabilities meets essential requirements. It identifies basic potential vulnerabilities within the authentication pages and	The analysis of XSS vulnerabilities is poorly conducted, with limited identification of issues within the authentication pages. The commentary lacks depth and fails to adequately explain	The analysis of XSS vulnerabilities is inadequate, failing to identify significant issues within the authentication pages. The commentary is superficial, offering little to no explanation

	comprehensive explanations are provided for each. The analysis covers both stored and reflected XSS vulnerabilities, offering detailed examples of how these could be exploited. Recommendations for mitigation are well-articulated, incorporating best practices and advanced techniques.	vulnerabilities and how they might be exploited, with minor areas requiring further detail. Recommendations for mitigation are practical and align with industry standards, though some advanced measures could be suggested.	provides a general overview of how they could be exploited. While the analysis may not be exhaustive, it highlights key security concerns and offers foundational recommendations for mitigation.	how vulnerabilities could be exploited. Mitigation recommendations are minimal and do not fully align with best practices, leaving potential security gaps.	of potential exploits or security risks. Mitigation recommendations are absent or ineffective, posing serious security threats.
c. SQL injection resistance	8–10 marks	6.5–7.5 marks	5–6 marks	4–4.5 marks	1–3.5 marks
	The demonstration of SQL injection resistance is executed with exceptional thoroughness. Three distinct SQL injection methods are meticulously tested, including techniques such as '1 OR 1=1', ensuring comprehensive coverage of potential vulnerabilities. Each test is documented in detail, with clear explanations of the expected outcomes and actual results. The authentication pages consistently prevent SQL injection, demonstrating robust protection through parameterised queries and secure coding practices.	The demonstration of SQL injection resistance is well-conducted, effectively testing three different injection methods. The tests, including common techniques like '1 OR 1=1', are performed with clear documentation of outcomes. The authentication pages show strong resistance to SQL injection, with minor areas for potential enhancement in security practices. The use of parameterised queries is evident, contributing to the overall security.	The demonstration of SQL injection resistance meets essential requirements. Three SQL injection methods, including basic techniques like '1 OR 1=1', are tested with satisfactory documentation of results. The authentication pages adequately resist these injection attempts, showing functional protection against SQL injection. While the demonstration may not cover all advanced techniques, it meets the basic requirements for security.	The demonstration of SQL injection resistance is poorly executed, with limited testing of injection methods. The tests lack depth, and documentation is minimal, providing insufficient insights into the outcomes. The authentication pages show partial resistance, with potential vulnerabilities remaining unaddressed. The implementation of secure coding practices such as parameterised queries is inconsistent.	The demonstration of SQL injection resistance is inadequate, with significant gaps in testing and documentation. The tested methods are insufficient and outcomes are not clearly recorded, leading to uncertainty about the security of the authentication pages. The pages are vulnerable to SQL injection, lacking effective protective measures.
Task 3: Evaluate a given website/web application against a range of measurable metrics					
Performance report	12–15 marks	10–11.5 marks	7.5–9.5 marks	6–7 marks	1–5.5 marks
	The performance report is exceptionally comprehensive,	The performance report is well-executed, testing the application on two devices.	The performance report meets essential requirements.	The performance report is poorly conducted, with limited	The performance report is inadequate, with significant gaps in testing and analysis.

	evaluating the application on at least two devices. The analysis is excellent and covers at least three criteria. The comparison of performance between devices is thorough, highlighting both strengths and areas for improvement. Potential issues are clearly identified and accompanied by well-considered solutions, demonstrating a deep understanding of each criterion. The summary is insightful, with detailed annotated screenshots and descriptions that effectively support the findings.	It provides a solid analysis of three criteria. The comparison between devices is clear, with identified issues and practical solutions for resolution. The summary is well-rounded, with annotated screenshots and descriptions enhancing the report's value. While the report is detailed, there may be minor areas for further depth or additional criteria coverage.	The application is tested on two devices, covering three criteria. The comparison of performance is adequate, highlighting basic differences and issues. Potential problems are identified with straightforward solutions, ensuring basic understanding and resolution. The summary includes necessary findings with supportive annotated screenshots and descriptions. While the report may lack advanced analysis or comprehensive coverage, it meets the basic requirements for functionality.	testing on tablet and mobile platforms. The analysis against the criteria is superficial. The comparison lacks depth, and potential issues are inadequately identified, with minimal solutions provided. The summary is basic, with insufficient screenshots or descriptions to support findings.	The application is not effectively tested on either device, and the criteria are either poorly covered or omitted. The comparison of performance is unclear, with few to no identified issues or solutions. The summary is lacking, with absent or inadequate screenshots and descriptions.
--	---	--	---	---	--